# Veille Techologique

## Les attaques DDoS

# Sommaire :

1. Introduction....4
2. Définition et fonctionnement des attaques DDoS....4
2.1. Principe général....4
2.2. Typologie des attaques DDoS....5
2.3. Tableau comparatif des attaques....5
2.4. Schéma de fonctionnement....6
3. Exemples d'attaques notables....6
3.1. L'attaque contre Dyn (2016)....6
3.2. L'attaque contre GitHub (2018)....6
3.3. Les attaques massives de 2023–2024 (Cloudflare & Google)....7
3.4. Les attaques DDoS en contexte géopolitique....7
3.5. Synthèse....7
4.1. Impacts économiques....7
4.2. Impacts réputationnels....8
4.3. Impacts techniques....8
4.4. Impacts sociétaux et géopolitiques....8
4.5. Tableau récapitulatif des impacts....9
5. Méthodes de protection et de mitigation....9
5.1. Approches préventives....9
5.2. Défenses au niveau du réseau....9
5.3. Défenses au niveau applicatif....9
5.4. Solutions externes (prestataires spécialisés)....10
5.5. Tableau des solutions de défense....10
5.6. Tableau Manquements / Améliorations / Remédiations....10
5.7. Tendances actuelles et futures....10
6. Méthodologie de veille technologique....11
6.1. Définition de la veille technologique....11
6.2. Objectifs de la veille....11
6.3. Sources utilisées....11
6.4. Outils de veille utilisés....12
6.5. Organisation du travail....12

# 1. Introduction

Avec la numérisation croissante de notre société, la disponibilité des systèmes et services informatiques est devenue un enjeu majeur. Les sites web, applications et infrastructures réseau doivent fonctionner en permanence pour garantir la satisfaction des utilisateurs et la continuité des activités économiques.

Parmi les menaces pesant sur cette disponibilité, les **attaques par déni de service distribué (DDoS)** occupent une place importante. Ces attaques consistent à saturer les ressources d'un service (serveur, application ou réseau) en générant un trafic massif provenant d'un grand nombre de machines compromises.

Le choix de ce thème s'explique par plusieurs raisons :

- Sa **pertinence dans le domaine SISR** (réseaux, matériel, cybersécurité).
- Sa forte **actualité** : les rapports de cybersécurité montrent que les attaques DDoS ne cessent d'augmenter en puissance et en fréquence.
- Sa **dimension pédagogique** : comprendre le fonctionnement d'un DDoS permet aussi de mieux cerner les stratégies de protection.

Ce dossier vise à expliquer le fonctionnement des attaques DDoS, à présenter leurs impacts, à analyser les moyens de protection existants, et à montrer comment une veille technologique peut aider à anticiper ces menaces.

# 2. Définition et fonctionnement des attaques DDoS

## 2.1. Principe général

Une attaque par déni de service distribué (**DDoS – Distributed Denial of Service**) est une cyberattaque qui vise à rendre un service informatique indisponible pour ses utilisateurs légitimes. Contrairement à une attaque DoS (Denial of Service) classique, menée depuis une seule machine, une attaque **DDoS implique une multitude de machines** réparties dans le monde entier, formant un **botnet**.

Un botnet est constitué d'ordinateurs, de serveurs, ou plus récemment d'objets connectés (IoT) infectés par un logiciel malveillant. Ces machines, appelées **"bots"** ou **"zombies"**, sont contrôlées à distance par un **serveur de commande et de contrôle (C&C)**, lui-même dirigé par l'attaquant.

Le processus est généralement le suivant :

1. L'attaquant prend le contrôle de milliers (voire millions) de machines vulnérables.
2. Ces machines obéissent aux ordres transmis par le coordinateur (C&C).
3. Toutes envoient simultanément un flux massif de requêtes vers la cible.
4. Le service victime est saturé et devient inutilisable.

Exemple concret : une attaque DDoS contre un site web peut générer des millions de requêtes HTTP par seconde, forçant le serveur à traiter un volume de demandes largement supérieur à ses capacités normales.

## 2.2. Typologie des attaques DDoS

Les attaques DDoS peuvent être classées en trois grandes catégories, selon le niveau qu'elles visent :

**Les attaques volumétriques**

- Objectif : saturer la **bande passante** du réseau de la victime.
- Méthodes : envoi massif de paquets (UDP flood, ICMP flood) ou attaques par **amplification** (DNS, NTP, SSDP).
- Exemple : une requête de 60 octets envoyée à un serveur DNS peut générer une réponse de 4 000 octets → amplification × 70.

**Les attaques protocolaires**

- Objectif : exploiter les **faiblesses des protocoles réseau** pour saturer les équipements intermédiaires (routeurs, firewalls, serveurs).
- Méthodes : **SYN flood** (inonde un serveur de requêtes de connexion TCP incomplètes), **ACK flood**.
- Exemple : dans une SYN flood, la cible alloue des ressources pour chaque connexion, mais ne reçoit jamais la confirmation finale.

**Les attaques applicatives**

- Objectif : cibler les **applications web** en envoyant des requêtes apparemment légitimes mais en grande quantité.
- Méthodes : **HTTP flood** (envoyer des milliers de requêtes GET/POST), attaques sur API.
- Exemple : simuler des milliers d'utilisateurs qui se connectent à un site e-commerce, saturant le serveur applicatif.

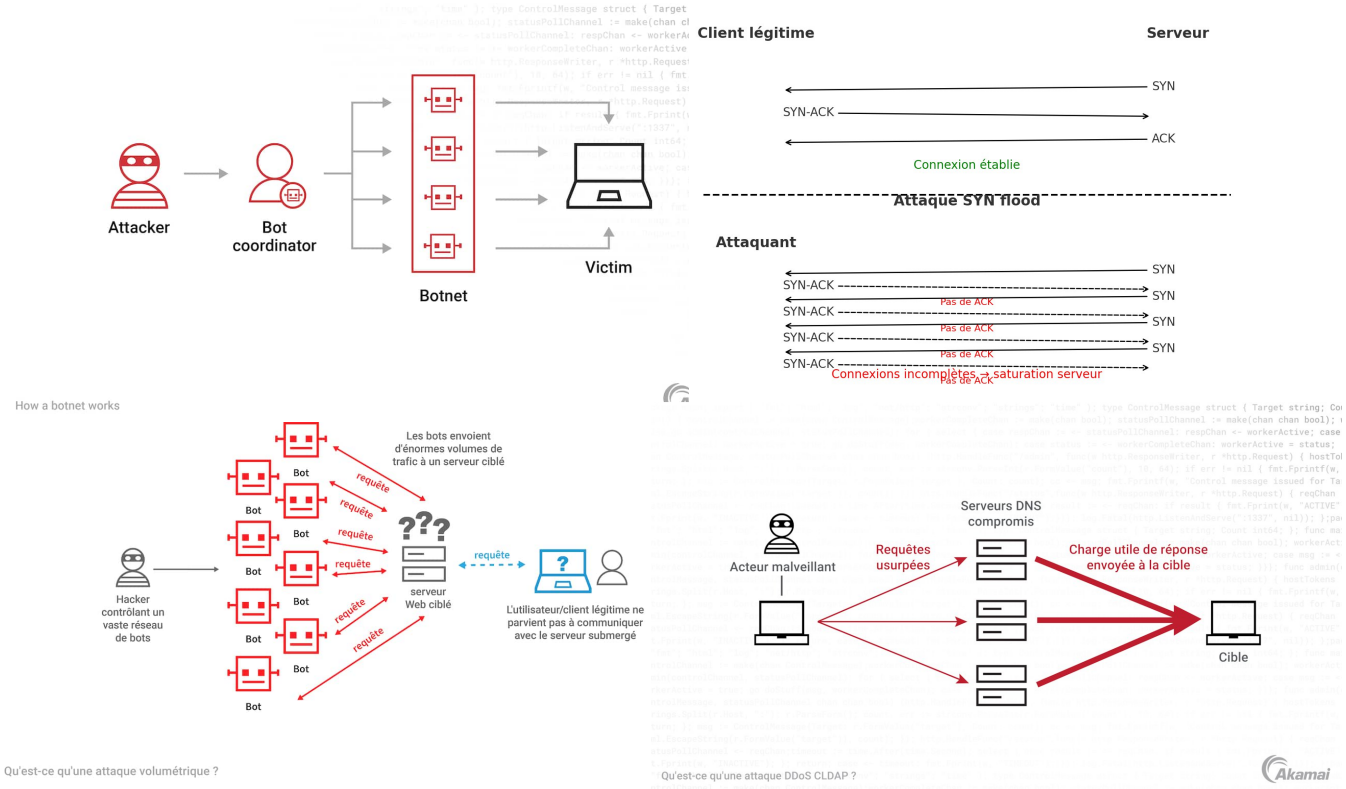
**Les attaques par réflexion/amplification**

- Objectif : amplifier le volume de trafic en exploitant des serveurs tiers mal configurés (DNS, NTP, SSDP…).
- Principe : l'attaquant envoie une petite requête falsifiée (en usurpant l'IP de la victime). Le serveur tiers renvoie une réponse **beaucoup plus volumineuse** directement vers la victime.
- Impact : multiplication du trafic (facteur ×50 à ×100), ce qui épuise rapidement la bande passante de la cible.
- Exemple : une requête DNS de 60 octets peut générer une réponse de 4 000 octets, amplification ×70.

## 2.3. Tableau comparatif des attaques

| Type d'attaque | Cible principale | Exemple | Impact attendu |
|---|---|---|---|
| **Volumétrique** | Bande passante réseau | UDP flood, ICMP flood | Saturation du lien Internet → trafic légitime bloqué |
| **Protocolaire** | Équipements réseau / serveurs | SYN flood, ACK flood | Surcharge CPU et mémoire → serveurs inaccessibles |
| **Réflexion / Amplification** | Bande passante via services UDP | Amplification DNS, NTP, SSDP | Réponses amplifiées saturent la cible → bande passante épuisée |
| **Applicative (couche 7)** | Applications et services web | HTTP flood, attaque sur API | Blocage du site ou ralentissement extrême des applications |

## 2.4. Schéma de fonctionnement




# 3. Exemples d'attaques notables

## 3.1. L'attaque contre Dyn (2016)

En octobre 2016, la société **Dyn**, fournisseur majeur de services DNS, a subi l'une des attaques DDoS les plus médiatisées. L'attaque a été menée par le **botnet Mirai**, composé

de centaines de milliers d'objets connectés vulnérables (caméras IP, routeurs domestiques, DVR).

- **Volume estimé** : environ 1,2 Tbps de trafic.
- **Cibles touchées indirectement** : Twitter, Netflix, Spotify, Reddit, Airbnb, PayPal…
- **Impact** : une partie importante d'Internet est devenue inaccessible en Amérique du Nord et en Europe pendant plusieurs heures.
- **Enseignement** : les objets connectés, souvent mal sécurisés, peuvent être utilisés massivement comme armes dans les cyberattaques.

## 3.2. L'attaque contre GitHub (2018)

En février 2018, la plateforme de développement **GitHub** a été victime d'une attaque DDoS record. Contrairement à Mirai, celle-ci utilisait une **amplification via le protocole Memcached**, qui permet de transformer de petites requêtes en réponses massives.

- **Volume** : 1,35 Tbps, à l'époque l'attaque la plus puissante jamais enregistrée.
- **Durée** : environ 20 minutes, grâce à une mitigation rapide.
- **Impact** : brève interruption de service, mais la réactivité des défenses a limité les dégâts.
- **Enseignement** : l'importance des services de protection externes (ici Akamai/Prolexic) pour absorber le trafic.

## 3.3. Les attaques massives de 2023–2024 (Cloudflare & Google)

Les rapports récents montrent une nouvelle escalade.

- En 2023, **Cloudflare** a signalé une attaque atteignant plus de **71 millions de requêtes HTTP par seconde** (record mondial à l'époque).
- En 2024, **Google Cloud** a révélé avoir bloqué une attaque dépassant **398 millions de requêtes par seconde**, probablement orchestrée par un botnet IoT combiné à des serveurs compromis.

Ces chiffres montrent que la **capacité des attaquants ne cesse de croître**, et que seule une infrastructure mondiale (CDN, anycast, scrubbing centers) peut absorber de tels volumes.

## 3.4. Les attaques DDoS en contexte géopolitique

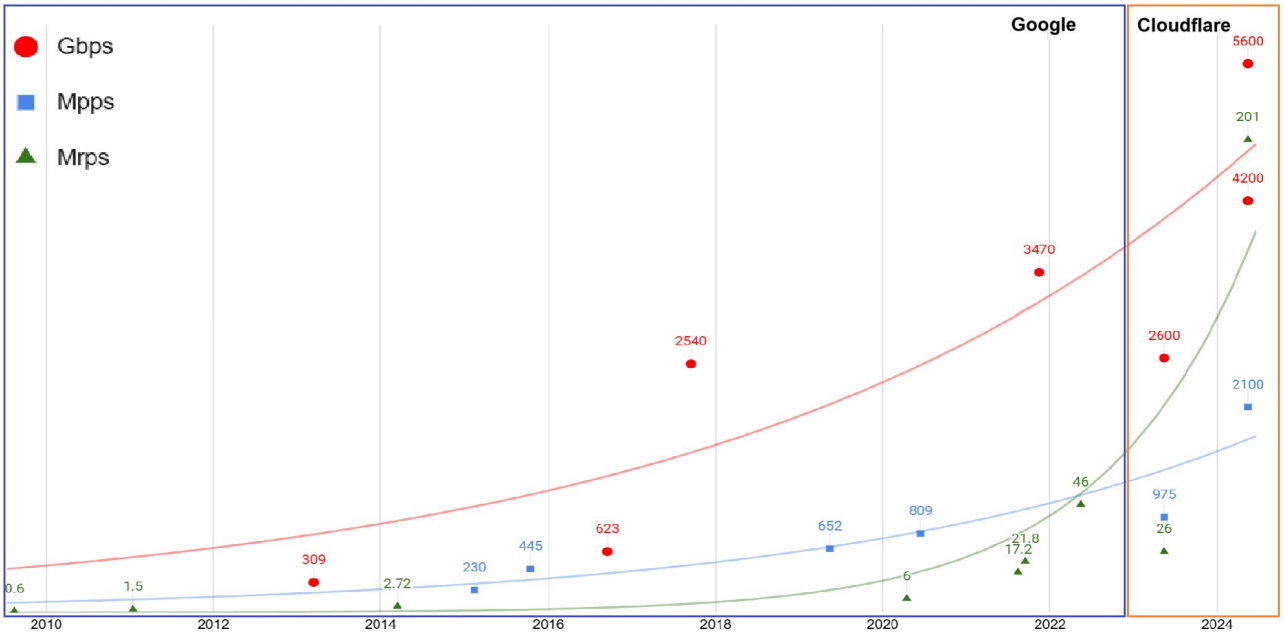
Depuis la guerre en Ukraine (2022), les DDoS sont également utilisés comme **armes de déstabilisation**. Plusieurs sites gouvernementaux et médias ukrainiens ont été paralysés par des attaques coordonnées, souvent attribuées à des groupes pro-russes.

- **Objectif** : perturber l'accès à l'information et miner la confiance dans les institutions.
- **Enseignement** : le DDoS n'est pas seulement un outil criminel, mais aussi un instrument de cyber-guerre.

### 3.5. Synthèse

Ces exemples montrent que :

- Les DDoS ne concernent pas seulement les grandes entreprises mais touchent aussi les services publics et stratégiques.
- L'ampleur des attaques augmente d'année en année (de quelques centaines de Gbps en 2016 à plusieurs centaines de millions de requêtes/s en 2024).
- L'évolution des techniques (botnets IoT, amplification, attaques applicatives) rend les défenses de plus en plus complexes.




*(Graphique de Cloudflare sur l'évolution de la puissance des attaques)*

## 4. Impacts des attaques DDoS

### 4.1. Impacts économiques

Les attaques DDoS peuvent entraîner des pertes financières considérables. Selon plusieurs études, le **coût moyen d'une attaque DDoS réussie varie de 50 000 à plus de 300 000 euros par heure d'indisponibilité**, en fonction de la taille de l'entreprise et de son secteur.

- **Perte de chiffre d'affaires direct** : un site e-commerce indisponible ne génère aucune vente.
- **Coûts indirects** : mobilisation des équipes techniques, dépenses liées aux prestataires de cybersécurité, compensation des clients.
- **Exemple** : Amazon avait estimé en 2023 qu'une heure d'arrêt complet pouvait représenter plus de **34 millions de dollars de pertes**.

## 4.2. Impacts réputationnels

La confiance des utilisateurs repose sur la **fiabilité** et la **disponibilité** des services. Lorsqu'un site ou une application tombe régulièrement en panne à cause d'attaques DDoS :

- Les clients risquent de se tourner vers des concurrents.
- L'image de l'entreprise peut être durablement dégradée.
- Dans certains secteurs sensibles (banques, santé, services publics), cela peut éroder la confiance des citoyens.

Exemple : en 2016, après l'attaque de Dyn, plusieurs médias ont titré sur « la fragilité d'Internet », ce qui a mis en lumière la dépendance critique aux infrastructures numériques.

## 4.3. Impacts techniques

Les conséquences techniques sont immédiates :

- **Saturation des serveurs** (CPU, mémoire, files d'attente réseau).
- **Blocage des routeurs et firewalls** incapables de traiter un volume de paquets anormalement élevé.
- **Interruption des services cloud** ou SaaS hébergés chez le même fournisseur.

Dans certains cas, les DDoS servent de **"couverts"** pour masquer une attaque plus grave (intrusion, vol de données) pendant que les équipes sont mobilisées sur la gestion de crise.

## 4.4. Impacts sociétaux et géopolitiques

Les DDoS ne touchent pas uniquement les entreprises privées. Ils sont parfois utilisés comme **armes de déstabilisation** dans des conflits géopolitiques ou pour perturber des services publics.

- Exemple : attaques contre des ministères et médias ukrainiens en 2022.
- Exemple : attaques visant des hôpitaux en Europe, paralysant temporairement leurs systèmes d'information.
- Risques : indisponibilité des services critiques (santé, énergie, transports), atteinte à la continuité de l'État.

## 4.5. Tableau récapitulatif des impacts

| Dimension | Exemple concret | Conséquence directe |
|---|---|---|
| Économique | E-commerce indisponible (Amazon, 2023) | Perte de millions €/heure |
| Réputationnelle | Dyn (2016) : coupure Internet massive | Baisse de confiance des clients |
| Technique | SYN flood sur serveurs d'entreprise | Surcharge CPU/mémoire |

| | | |
|---|---|---|
| Sociétale | Attaques sur hôpitaux et ministères | Perturbation services critiques |

# 5. Méthodes de protection et de mitigation

Les attaques DDoS ne peuvent pas être totalement évitées, mais il existe de nombreuses **stratégies de protection et d'atténuation (mitigation)**. Celles-ci agissent à différents niveaux : matériel, réseau, applicatif, et via des prestataires spécialisés.

## 5.1. Approches préventives

Avant même une attaque, plusieurs bonnes pratiques permettent de réduire la vulnérabilité d'une infrastructure :

- **Surveillance proactive** : mise en place de systèmes de monitoring pour détecter les anomalies de trafic en temps réel.
- **Architecture redondante** : répartition des services sur plusieurs serveurs, centres de données ou zones géographiques.
- **Tests réguliers de résilience** : simulations d'attaques (stress tests) pour évaluer la capacité de résistance.

## 5.2. Défenses au niveau du réseau

- **Pare-feu et routeurs configurés** : filtrage basique des flux suspects, limitation des connexions incomplètes.
- **Load balancing** : répartition de la charge entre plusieurs serveurs pour éviter la saturation d'un seul point.
- **Anycast** : diffusion du service sur plusieurs emplacements géographiques, permettant de disperser le trafic et d'absorber plus efficacement les attaques.
- **CDN (Content Delivery Network)** : comme Cloudflare ou Akamai, qui disposent d'une infrastructure mondiale capable d'absorber d'énormes volumes de trafic.

## 5.3. Défenses au niveau applicatif

- **WAF (Web Application Firewall)** : filtre les requêtes HTTP/HTTPS pour bloquer les patterns malveillants.
- **Systèmes de détection IDS/IPS** : identifient et bloquent les anomalies réseau.
- **Limitation de débit (rate limiting)** : empêche un utilisateur ou une IP d'envoyer trop de requêtes en un temps donné.

## 5.4. Solutions externes (prestataires spécialisés)

De nombreuses entreprises font appel à des **services de mitigation DDoS** proposés par des fournisseurs spécialisés (FAI, hébergeurs, sociétés de cybersécurité).

- **Scrubbing centers** : filtrent le trafic entrant en supprimant les paquets malveillants avant qu'ils n'atteignent la cible.

- **Blackholing / Sinkholing** : redirigent le trafic vers une “poubelle numérique” pour éviter la saturation des serveurs.
- **Protection cloud** : Google Cloud Armor, AWS Shield, Azure DDoS Protection, etc.

### 5.5. Tableau des solutions de défense

| Niveau | Solution | Exemple concret | Limites |
|---|---|---|---|
| Réseau | Anycast, CDN | Cloudflare, Akamai | Coût élevé, dépendance externe |
| Matériel/Local | Firewall, IDS/IPS | pfSense, Snort | Peu efficace seul face aux gros volumes |
| Applicatif | WAF, Rate limiting | ModSecurity, Nginx | Ne couvre pas les attaques volumétriques |
| Fournisseur (FAI) | Scrubbing, Blackholing | OVHcloud, Orange Cyberdefense | Risque de coupure de service |
| Cloud | DDoS Protection Service | AWS Shield, Google Armor | Payant, nécessite expertise |

### 5.6. Tableau Manquements / Améliorations / Remédiations

| Manquement identifié | Amélioration possible | Remédiation proposée |
|---|---|---|
| IoT non sécurisé | Mise à jour régulière des firmwares | Segmentation réseau des objets |
| Absence de plan de réponse | Élaboration d’un PRA/PCA | Simulations d’attaques régulières |
| Détection trop tardive | Outils SIEM avec alertes | Supervision en temps réel |
| Serveur unique | Répartition de charge (load bal.) | Infrastructure redondante |

### 5.7. Tendances actuelles et futures

- **Intelligence artificielle (IA)** : de plus en plus utilisée pour détecter des anomalies comportementales et réagir automatiquement.
- **Edge computing** : traitement plus proche des utilisateurs pour absorber les attaques dès la périphérie du réseau.
- **Normes de sécurité IoT** : visant à réduire la vulnérabilité des objets connectés exploités dans les botnets.

## 6. Méthodologie de veille technologique

### 6.1. Définition de la veille technologique

La veille technologique est une démarche qui consiste à **surveiller en continu l’évolution des technologies** et à collecter des informations pertinentes afin d’anticiper les changements, les risques et les opportunités. Dans le cadre de ce dossier, la veille s’est focalisée sur le thème des attaques DDoS, en lien avec la cybersécurité et l’administration des réseaux (BTS SIO option SISR).

## 6.2. Objectifs de la veille

- Suivre l'évolution des **techniques d'attaques DDoS** (nouvelles méthodes, amplification, botnets IoT).
- Identifier les **tendances récentes** (hausse des puissances d'attaques, contexte géopolitique).
- Étudier les **solutions de défense** proposées par les acteurs du marché (FAI, hébergeurs, solutions cloud).
- Sélectionner des **cas concrets** récents pour illustrer la menace.

## 6.3. Sources utilisées

Pour assurer la fiabilité et la pertinence des informations, les sources ont été sélectionnées selon plusieurs critères :

- **Fiabilité** : sites institutionnels, entreprises reconnues en cybersécurité.
- **Actualité** : publications récentes (moins de 3 ans pour la majorité).
- **Pertinence** : contenu en lien direct avec les attaques DDoS et la cybersécurité.

**Sources institutionnelles**

- **ANSSI (Agence nationale de la sécurité des systèmes d'information)** : https://www.ssi.gouv.fr
- **CERT-FR (Centre gouvernemental de veille, d'alerte et de réponse aux attaques informatiques)** : https://www.cert.ssi.gouv.fr

**Sources professionnelles et rapports annuels**

- **Cloudflare DDoS Threat Report (2024)** : statistiques et analyses des attaques mondiales.
  https://blog.cloudflare.com
- **Akamai – State of the Internet / Security Report (2023)** : tendances globales de sécurité.
  https://www.akamai.com
- **Google Cloud Armor Blog** : rapport sur les attaques DDoS record (2023-2024).
  https://cloud.google.com/blog

**Sites d'actualités spécialisés en informatique**

- **ZDNet France** : https://www.zdnet.fr
- **Le Monde Informatique** : https://www.lemondeinformatique.fr
- **01Net** : https://www.01net.com
- **Blogs techniques et veille**
- **Tech2Tech (blog IT français)** : bonnes pratiques de veille et cybersécurité.
  https://www.tech2tech.fr
- **Generation NT** : https://www.generation-nt.com

### 6.4. Outils de veille utilisés

- **Flux RSS** des sites spécialisés (ZDNet, Le Monde Informatique).
- **Alertes Google** sur les mots-clés *“attaque DDoS”*, *“mitigation DDoS”*, *“botnet IoT”*.
- **Rapports PDF** téléchargés sur les sites officiels (ANSSI, Cloudflare, Akamai).

### 6.5. Organisation du travail

- **Collecte** : recensement des articles, rapports et actualités récentes.
- **Tri** : élimination des sources non fiables ou trop anciennes.
- **Classement** : par thématiques (types d’attaques, exemples, défenses, tendances).
- **Synthèse** : rédaction du dossier et préparation du diaporama.

## 7. Conclusion personnelle

L’étude des attaques DDoS m’a permis de mieux comprendre l’un des principaux risques qui pèsent aujourd’hui sur la disponibilité des services numériques. Derrière une définition apparemment simple – saturer une cible de requêtes – se cachent en réalité des méthodes extrêmement variées et de plus en plus sophistiquées.

Ce sujet m’a marqué par son **actualité** : chaque année, des records de puissance d’attaques sont battus, et les DDoS ne concernent plus seulement les grandes entreprises internationales. Des administrations publiques, des hôpitaux et même des PME locales peuvent en être victimes. Cela montre que la cybersécurité n’est pas un luxe mais une nécessité pour toutes les organisations.

En tant qu’étudiant en **BTS SIO option SISR**, j’ai trouvé ce thème particulièrement intéressant car il relie directement les trois dimensions de notre formation :

- **Réseau (B1)** : comprendre comment le trafic circule et peut être saturé.
- **Matériel (B2)** : analyser le rôle des équipements compromis (IoT, serveurs, routeurs).
- **Cybersécurité (B3)** : explorer les solutions de défense (firewalls, WAF, scrubbing centers).

Ce travail de veille m’a aussi fait prendre conscience de l’importance de **rester en alerte** et de se tenir informé en continu. Les menaces évoluent vite, et un bon administrateur système et réseau doit être capable d’anticiper les nouvelles techniques d’attaque.

À titre personnel, je retiens que les DDoS illustrent bien la double face d’Internet : un réseau mondial, puissant et indispensable, mais aussi vulnérable dès lors que ses règles de fonctionnement sont exploitées à mauvais escient. À l’avenir, j’aimerais approfondir mes connaissances sur les **solutions de mitigation en cloud** et l’utilisation de l’**IA pour la détection des attaques**, car je pense que ce seront des compétences essentielles pour exercer dans les métiers de la cybersécurité et de l’administration réseau.